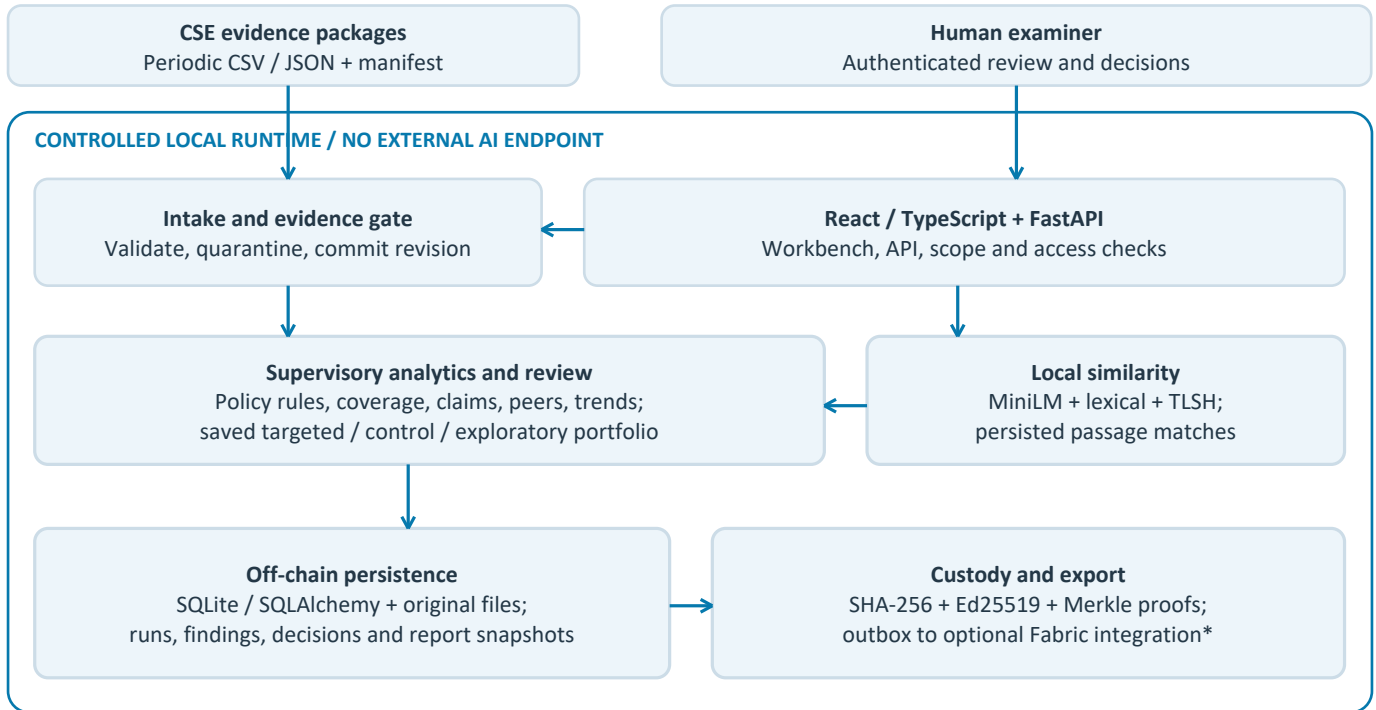


SAT-SA

Supervisory Analytics Tool for SOC Assessment

An offline decision-support workbench for NCIIPC examiners assessing Critical Sector Entities (CSEs) from periodic SOC evidence. It identifies review priorities, exposes uncertainty and preserves traceable human decisions. It does not provide real-time SIEM monitoring or autonomous regulatory verdicts.

1. Logical architecture and trust boundary



*Fabric is an optional commitment-anchoring layer. The current adapter returns simulated receipts; live network anchoring is not verified. Raw cases remain off-chain.

2. Components and responsibilities

Component / technology	Responsibility
Web and API React, TypeScript, FastAPI, Pydantic	Entity/period navigation, intake, findings, comparisons, examiner review and exports. Session, CSRF and entity-scope checks at the API boundary.
Ingestion and analytics Python, NumPy	Preserve native IDs and source locators; assess evidence sufficiency, investigation/escalation obligations, coverage, claims, recurrence and unusual patterns.
Similarity and selection MiniLM, TLSH, greedy selection	Local passage retrieval with explicit method labels; budgeted review portfolio maximizing useful coverage under diversity constraints. Similarity is a review lead.
Persistence and custody SQLite, SQLAlchemy, Alembic, cryptography	Relational provenance and versioned records; retained source files; separate human decisions; signed custody milestones and frozen report artifacts.

Operational architecture

3. Assessment lifecycle

1. Receive and qualify: bind the manifest and files to an entity, period and revision. Preserve exact bytes and SHA-256 digests; parse/normalize records and track accepted, rejected and quarantined counts. Commit the evidence revision before assessment.

2. Assess and explain: evaluate applicable policies at the decision cutoff. Check completeness before interpreting absent actions or KPI denominators. Generate cited findings with evidence states and alternatives; freeze rule/model configuration. Missing evidence remains unknown, not an automatic adverse conclusion.

3. Select and review: persist a mixed portfolio of case, asset-period, source-period and claim-cohort items. Examiners inspect sources, record reasoned decisions or request clarifying evidence. Human revisions retain lineage without overwriting machine findings.

4. Freeze and verify: export point-in-time HTML/JSON with checksums, ZIP packaging and detached proof data. Later evidence, decisions or receipts do not silently change old report bytes. Independent verification checks artifacts against trusted digests, keys and checkpoints.

4. Data model and evidence provenance

Core lineage: Entity → Submission revision → Source file → Raw/normalized record → Assessment run → Finding / Review item → Human decision → Report snapshot. Related records include policies, claims, passage matches, evidence requests, custody events, checkpoints and ledger-outbox entries.

SQL stores structured records and relationships; local files retain source bytes, model artifacts and exports. File hashes, native record IDs and row/character locators support drill-down. SHA-256 checks exact integrity; TLSH and embeddings measure similarity. Neither a hash nor a ledger proves that the original submission was truthful.

5. Security, AI and distributed trust

Boundary	Architectural control / limitation
Access and isolation	Authenticated sessions, CSRF checks and server-side entity authorization. Peer aggregates must not reveal another entity's raw narratives. Private evidence and keys require OS access controls, disk encryption and backups.
Local AI	Pinned all-MiniLM-L6-v2, verified safetensors and local inference. Overlapping chunks retain exact source spans; saved retrieval is read-only. Off / auto / required modes expose disabled, fallback or unavailable states.
Custody and ledger	Ed25519 signatures, event sequencing and Merkle checkpoints support verification with independently trusted keys. An outbox separates local recording from optional Fabric anchoring of commitments, not case content. Retained independent checkpoints address rollback detection.

6. Deployment and readiness

The local prototype serves React through Vite on 127.0.0.1:5173 and FastAPI/Uvicorn on 127.0.0.1:8000; SQLite and model inference run locally. Docker/Nginx configuration also exists. A CPU workstation with 16 GB RAM and SSD is a proposed evaluation baseline, not a certified minimum. Measure throughput and concurrency before scaling persistence or inference.

Current boundary: Source and demo data contain simulated Fabric receipts. Verify a real Gateway transaction before claiming live anchoring. A release archive and manifest checks are reported, but clean disconnected startup requires all runtime dependencies and independently provisioned trust keys. Synthetic tests do not establish production or expert-equivalent effectiveness.

Basis: project architecture, model card, review policy, evidence trust model, API/configuration and Fabric adapter source. Updated 29 September 2026; selected-source review, not deployment certification.